

报告编号 XXXXXXXXXXXX-XXXXX-XX-XXXX-XX

网络安全等级保护
[被测对象名称]等级测评报告

被测单位：_____

测评单位：_____

报告时间：_____年 月 日_____

说明：

一、每个备案系统单独出具测评报告。

二、测评报告编号为四组数据。各组含义和编码规则如下：

第一组为系统备案表编号，由 2 段共 16 位数字组成，可以从公安机关颁发的系统备案证明（或备案回执）上获得。第 1 段即备案证明编号的前 11 位（前 6 位为受理备案公安机关代码，后 5 位为受理备案的公安机关给出的备案单位的顺序编号）；第 2 段即备案证明编号的后 5 位（系统编号）。

第二组为年份，由 2 位数字组成。例如 09 代表 2009 年。

第三组为机构代码，由网络安全等级测评与检测评估机构服务认证证书编号最后四位数字组成。

第四组为本年度系统测评次数，由两位构成。例如 02 表示该系统本年度测评 2 次。

网络安全等级测评基本信息表

被测对象					
被测对象名称				安全保护等级	
备案证明编号				统一社会信用代码	
被测单位					
单位名称					
单位地址				邮政编码	
联系人	姓 名		职务/职称		
	所属部门		办公电话		
	移动电话		电子邮件		
测评单位					
单位名称				机构代码	
单位地址				邮政编码	
联系人	姓 名		职务/职称		
	所属部门		办公电话		
	移动电话		电子邮件		
审核批准	编制人	(签字)	编制日期		
	审核人	(签字)	审核日期		
	批准人	(签字)	批准日期		

声明

【填写说明：声明是测评机构对测评报告的有效性前提、测评结论的适用范围以及使用方式等有关事项的陈述，测评机构可参考以下建议内容编制。】

本报告是[被测对象名称]（备案证明编号：[备案证明编号]）的等级测评报告。

本报告测评结论的有效性建立在被测评单位提供相关证据的真实性基础之上。

本报告中给出的测评结论仅对被测对象当时的安全状态有效。当测评工作完成后，由于被测对象发生变更而涉及到的系统构成组件（或子系统）本报告不再适用。

本报告中给出的测评结论不能作为对被测对象内部部署的相关系统构成组件（或产品）的测评结论。

在任何情况下，若需引用本报告中的测评结果或结论都应保持其原有的意义，不得对相关内容擅自进行增加、修改和伪造或掩盖事实。

单位名称（加盖单位公章或等级测评业务专用章）

年 月

等级测评结论

【填写说明：表项“第Z级（SXAY）”中，“第Z级”表示被测对象的安全保护等级，“Z”的取值为（一、二、三、四或五）；“SX”和“AY”分别表示被测对象的业务信息和系统服务安全保护等级，X和Y的取值为（1、2、3、4或5），如第三级（S3A3）。如果被测对象由独立定级的云计算平台或大数据平台提供平台支撑，或者自身为独立定级的云计算平台或大数据平台，则需填写等级测评结论扩展表（云计算安全）或等级测评结论扩展表（大数据安全），否则删除等级测评结论扩展表。】

测评结论和重大风险隐患			
被测对象名称		安全保护等级	第Z级（SXAY）
扩展要求 应用情况	☐云计算 ☐工业控制系统 ☐移动互联 ☐大数据 ☐物联网 ☐其他_____		
被测对象描述	【填写说明：简要描述被测对象承载的业务功能等基本情况，包括被测对象的子系统情况，建议不超过300字】		
安全状况描述	【填写说明：根据实际测评情况简要描述被测对象的整体安全状况，包括最主要的中高风险安全问题及数量，建议不超过400字】 【参考示例】 本次安全等级测评采用访谈、核查和测试等测评方法，对【被测对象名称】的【物理机房、网络架构、网络设备、安全设备、系统管理软件、主机操作系统、数据库管理系统、业务应用系统、数据资源、管理制度】等具体对象实施了测评。通过测评发现，在安全技术方面具备【网络结构冗余、区域边界隔离、边界访问控制、双因子身份鉴别、账户权限控制、操作日志审计、入侵检测、恶意代码查杀、设备冗余部署、数据定期备份】等安全技术措施。在安全管理方面【制定了信息安全管理体系及相关制度和流程，具备实施记录，组建了安全运维团队】。 本次安全等级测评共发现【被测对象名称】存在高风险问题【X】个，中风险问题【X】个，低风险问题【X】个。【被测对象名称】技术方面尚有一些问题需要整改和完善，信息安全管理体系执行情况还可以进一步提高。		
等级测评结论	【填写说明：除填写测评结论外，还需加盖测评机构单位公章或等级测评业务专用章】	重大风险隐患数量	

重大风险隐患及整改建议

【填写说明：描述被测对象存在的全部重大风险隐患，并提出整改建议，整改建议应具有针对性、全面性、整体性。既要保证相关整改建议能够落地实施，又要能够全面的、系统性解决所面临的重大风险隐患。

对于在测评过程中所发现的重大风险隐患已完成整改的，需如实描述，同时注明（已整改）。如果没有重大风险隐患，则注明未发现重大风险隐患，例如“经过单项测评结果判定和整体测评，未发现[被测对象名称]存在重大风险隐患。”。测评机构可参考以下示例编制。】

经过单项测评结果判定和整体测评，[被测对象名称]存在重大风险隐患 XX 项，截止报告发布日期，已完成整改 XX 项，剩余 XX 项未整改。本次测评过程中发现的重大风险隐患及整改建议如下：

（1）存在空口令、弱口令、通用口令或无身份鉴别措施，导致非授权人员可直接访问系统，造成身份冒用、恶意篡改或窃取重要数据等严重后果。

整改建议：为每个可登录的账户设置符合要求的口令，禁用或删除弱口令账户；设置的口令长度应不低于 8 位，并由大小写字母、特殊字符和数字无规律排列而成；同时应定期排查空口令、弱口令、通用口令的使用情况，及时发现并阻止账户口令违规行为，确保账户安全。

（2）获取被测系统权限导致非授权人员访问系统和获取重要权限，造成业务中断、重要数据泄露等严重后果。（已整改）

整改建议：无。

（3）重大风险隐患 3 描述

整改建议：整改建议描述

等级测评结论扩展表（云计算安全）

【填写说明】

- 1、“被测对象云计算形态”用于明确被测对象是云计算平台还是云服务客户业务应用系统，此处为单选。“被测对象采用的云计算服务模式”用于描述被测对象所采用的云计算服务模式，此处为单选。当云计算形态为云服务客户业务应用系统时，“云计算平台名称”填写该被测对象所使用的云计算平台名称。
- 2、“云计算平台服务能力描述”给出了当前服务模式下云计算平台为云服务客户提供的服务能力符合情况，以及云计算平台的等级测评结论和综合得分。需要注意的是，表中以第四级为例给出了云计算安全扩展主要要求，测评机构应根据被测对象安全保护等级情况，参照表中内容给出相应等级的云计算安全扩展主要要求。
- 3、如果云服务客户业务应用系统同时部署在不同模式的云计算平台上时，可以使用多个等级测评结论扩展表（云计算安全）来展示。
- 4.当被测对象不涉及相关扩展要求时，删除该结论扩展表。

【说明结束】

等级测评结论扩展表（云计算安全）			
被测对象云计算形态	☐云计算平台 ☐云服务客户业务应用系统（平台报告编号：_____） 【填写说明：填写该云服务客户业务应用系统在当前服务模式下所使用的云计算平台的等级测评报告编号。】		
云计算平台名称		被测对象采用的云计算服务模式	☐IaaS ☐PaaS ☐SaaS
云计算平台服务能力描述			
云计算安全扩展主要要求			符合情况
网络架构	b)应实现不同云服务客户虚拟网络之间的隔离；		
	c)应具有根据云服务客户业务需求提供通信传输、边界防护、入侵防范等安全机制的能力；		

	e)应提供开放接口或开放性安全服务，允许云服务客户接入第三方安全产品或在云计算平台选择第三方安全服务；	
	f)应提供对虚拟资源的主体和客体设置安全标记的能力，保证云服务客户可以依据安全标记和强制访问控制规则确定主体对客体的访问；	
	g) 应提供通信协议转换或通信协议隔离等的 数据交换方式，保证云服务客户可以根据业务需求自主选择边界数据交换方式。	
入侵防范	a)应能检测到云服务客户发起的网络攻击行为，并能记录攻击类型、攻击时间、攻击流量等。	
安全审计	b)应保证云服务商对云服务客户系统和数据的操作可被云服务客户审计。	
数据完整性和 保密性	c)应使用校验技术或密码技术保证虚拟机迁移过程中重要数据的完整性，并在检测到完整性受到破坏时采取必要的恢复措施；	
	d)应支持云服务客户部署密钥管理解决方案，保证云服务客户自行实现数据的加解密过程。	
数据备份恢复	b)应提供查询云服务客户数据及备份存储位置的能力；	
	d)应为云服务客户将业务系统及数据迁移到其他云计算平台和本地系统提供技术手段，并协助完成迁移过程。	
剩余信息保护	b)云服务客户删除业务应用数据时，云计算平台应将云存储中所有副本删除。	
供应链管理	b)应将供应链安全事件信息或安全威胁信息及时传达到云服务客户。	
云计算平台等级测评结论		云计算平台重大风险隐患数量

等级测评结论扩展表（大数据安全）

【填写说明】

- 1、“被测对象大数据形态”用于明确被测对象的大数据形态是否包括大数据平台、大数据应用或大数据资源，此处为多选。当大数据形态为大数据应用或大数据资源时，“大数据平台名称”填写承载大数据业务所使用的大数据平台名称。
- 2、“大数据平台服务能力描述”给出了大数据平台的服务能力符合情况，以及大数据平台的等级测评结论和综合得分。需要注意的是，表中以第四级为例给出了大数据安全扩展主要要求，测评机构应根据被测对象安全保护等级情况，参照表中内容给出相应等级的大数据安全扩展主要要求。
- 3.当被测对象不涉及相关扩展要求时，删除该结论扩展表。

【说明结束】

等级测评结论扩展表（大数据安全）		
被测对象大数据形态	☐大数据平台 ☐大数据应用（平台报告编号：_____） ☐大数据资源（平台报告编号：_____） 【填写说明：当大数据资源或大数据应用采用大数据平台提供方提供平台支撑时，平台报告编号为该大数据平台的等级测评报告编号。】	
大数据平台名称		
大数据平台服务能力描述		
大数据安全扩展主要要求		符合情况
数据隔离	b)应保证大数据平台的管理流量与系统业务流量分离；	
	g)对外提供服务的大数据平台，平台或第三方只有在大数据应用授权下才可以对大数据应用的数据资源进行访问、使用和管理；	
	n)大数据平台应保证不同客户大数据应用的审计数据隔离存放。	
静态脱敏和去标识化	f)大数据平台应提供静态脱敏和去标识化的工具或服务组件技术。	
安全审计	n)大数据平台应提供不同客户审计数据收集汇总和集中分析的能力。	

访问控制	i)大数据平台应提供设置数据安全标记功能，基于安全标记的授权和访问控制措施，满足细粒度授权访问控制管理能力要求。	
数据分类分级的标识	h)大数据平台应提供数据分类分级安全管理功能，供大数据应用针对不同类别级别的数据采取不同的安全保护措施；	
	j)大数据平台应在数据采集、存储、处理、分析等各个环节，支持对数据进行分类分级处置，并保证安全保护策略保持一致；	
	o)大数据平台应具备对不同类别、不同级别数据全生命周期区分处置的能力。	
数据溯源	m)应跟踪和记录数据采集、处理、分析和挖掘等过程，保证溯源数据能重现相应过程，溯源数据满足合规审计要求。	
资源管理	c)大数据平台应为大数据应用提供集中管控其计算和存储资源使用状况的能力；	
	e)大数据平台应屏蔽计算、内存、存储资源故障，保障业务正常运行。	
大数据平台等级测评结论		大数据平台重大风险隐患情况

目录

网络安全等级测评基本信息表I

声明 II

等级测评结论 III

重大风险隐患及整改建议IV

等级测评结论扩展表（云计算安全） V

等级测评结论扩展表（大数据安全） VII

1 测评项目概述 1

 1.1 测评目的 1

 1.2 测评依据 1

 1.3 测评过程 2

 1.4 报告分发范围 2

2 被测对象描述 2

 2.1 被测对象概述 2

 2.1.1 定级结果 2

 2.1.2 业务和采用的技术 2

 2.1.3 网络结构 3

 2.2 测评指标 3

 2.2.1 安全通用要求指标 3

 2.2.2 安全扩展要求指标 3

 2.2.3 其他安全要求指标 4

 2.2.4 不适用安全要求指标 4

 2.3 测评对象 4

 2.3.1 测评对象选择方法 4

 2.3.2 测评对象选择结果 4

3 单项测评结果分析 7

 3.1 安全物理环境 7

 3.1.1 已有安全控制措施汇总分析 7

 3.1.2 主要安全问题汇总分析 8

 3.2 安全通信网络 8

3.2.1	已有安全控制措施汇总分析	8
3.2.2	主要安全问题汇总分析	8
3.3	安全区域边界	8
3.3.1	已有安全控制措施汇总分析	8
3.3.2	主要安全问题汇总分析	8
3.4	安全计算环境	8
3.4.1	网络设备	9
3.4.2	安全设备	9
3.4.3	服务器和终端	9
3.4.4	系统管理软件/平台	10
3.4.5	业务应用系统/平台	10
3.4.6	数据资源	11
3.4.7	其他系统或设备	11
3.5	安全管理中心	12
3.5.1	已有安全控制措施汇总分析	12
3.5.2	主要安全问题汇总分析	12
3.6	安全管理制度	12
3.6.1	已有安全控制措施汇总分析	12
3.6.2	主要安全问题汇总分析	12
3.7	安全管理机构	12
3.7.1	已有安全控制措施汇总分析	12
3.7.2	主要安全问题汇总分析	12
3.8	安全管理人员	12
3.8.1	已有安全控制措施汇总分析	12
3.8.2	主要安全问题汇总分析	13
3.9	安全建设管理	13
3.9.1	已有安全控制措施汇总分析	13
3.9.2	主要安全问题汇总分析	13
3.10	安全运维管理	13
3.10.1	已有安全控制措施汇总分析	13
3.10.2	主要安全问题汇总分析	13

3.11	其他安全要求指标	13
3.11.1	已有安全控制措施汇总分析	13
3.11.2	主要安全问题汇总分析	13
3.12	验证测试	13
3.12.1	漏洞扫描	14
3.12.2	渗透测试	15
3.13	安全问题汇总	15
4	整体测评	16
4.1	安全控制点间安全测评	16
4.2	区域间安全测评	16
4.3	整体测评结果汇总	17
5	安全问题风险分析	17
5.1	低中高风险安全问题分析	17
5.2	重大风险隐患分析	18
6	总体评价	19
7	等级测评结论	21
8	安全问题整改建议	22
8.1	低中高风险安全问题整改建议	22
8.2	重大风险隐患整改建议	22
附录 A	被测对象资产	24
A.1	物理机房	24
A.2	网络设备	24
A.3	安全设备	24
A.4	服务器	24
A.5	终端设备	25
A.6	其他系统或设备	25
A.7	系统管理软件/平台	26
A.8	业务应用系统/平台	26
A.9	数据资源	26
A.10	密码产品	27
A.11	安全相关人员	27

A.12 安全管理文档 27

附录 B 上次测评问题整改情况说明 27

附录 C 单项测评结果汇总 28

 C.1 安全物理环境 28

 C.2 安全通信网络 29

 C.3 安全区域边界 29

 C.4 安全计算环境 29

 C.4.1 网络设备 29

 C.4.2 安全设备 29

 C.4.3 服务器和终端 29

 C.4.4 系统管理软件/平台 29

 C.4.5 业务应用系统/平台 30

 C.4.6 数据资源 30

 C.4.7 其他系统或设备 30

 C.5 安全管理中心 30

 C.6 安全管理制度 30

 C.7 安全管理机构 30

 C.8 安全管理人员 30

 C.9 安全建设管理 30

 C.10 安全运维管理 30

 C.11 其他安全要求指标 31

附录 D 单项测评结果记录 31

 D.1 安全物理环境 31

 D.1.1 安全通用要求部分 31

 D.1.2 安全扩展要求部分 31

 D.2 安全通信网络 32

 D.2.1 安全通用要求部分 32

 D.2.2 安全扩展要求部分 32

 D.3 安全区域边界 32

 D.3.1 安全通用要求部分 32

 D.3.2 安全扩展要求部分 32

D.4 安全计算环境 32

 D.4.1 安全通用要求部分 32

 D.4.2 安全扩展要求部分 33

D.5 安全管理中心 33

 D.5.1 安全通用要求部分 33

 D.5.2 安全扩展要求部分 33

D.6 安全管理制度 33

 D.6.1 安全通用要求部分 33

 D.6.2 安全扩展要求部分 33

D.7 安全管理机构 34

 D.7.1 安全通用要求部分 34

 D.7.2 安全扩展要求部分 34

D.8 安全管理人员 34

 D.8.1 安全通用要求部分 34

 D.8.2 安全扩展要求部分 34

D.9 安全建设管理 34

 D.9.1 安全通用要求部分 34

 D.9.2 安全扩展要求部分 34

D.10 安全运维管理 34

 D.10.1 安全通用要求部分 34

 D.10.2 安全扩展要求部分 35

D.11 其他安全要求 35

附录 E 漏洞扫描结果记录 35

附录 F 渗透测试结果记录 35

 F.1 XX 安全问题 1 35

 F.2 XX 安全漏洞 2 35

附录 G 重大风险隐患触发项参照表 35

附录 H 重大风险隐患及整改情况 44

 H.1 重大风险隐患 1（已整改） 44

 H.2 重大风险隐患 2 45

附录 I 威胁列表 45

附录 J 云计算平台测评及整改情况46

附录 K 大数据平台测评及整改情况46

1 测评项目概述

【格式说明】

- (1) 正文：华文仿宋和 Times New Roman，小四，1.5 倍行距。
- (2) 标题：中文第一级标题为三号黑体加粗，其他标题为四号黑体加粗，西文为 Times New Roman。
- (3) 表格正文：华文仿宋和 Times New Roman，常规，五号，单倍行距。
- (4) 表格第一行：华文仿宋和 Times New Roman，加粗，五号，单倍行距，底纹为深色 35%。
- (5) 题注：黑体和 Times New Roman，加粗，五号，单倍行距。
- (6) 页眉页脚：华文仿宋和 Times New Roman，加粗，小五，单倍行距。
- (7) 注意首页不同，不使用 Word 兼容格式，容易造成格式混乱。
- (8) 全文段前段后为 0（包括所有标题）。
- (9) 全文页码序号分为正文及前面两部分。
- (10) 表格和插图有题注。
- (11) 所有正文中涉及数字序号为（1），不是半括号 1）。
- (12) 全文页眉页脚格式正确。报告完成后检查最后一页的页码，更新目录。

【说明结束】

1.1 测评目的

【填写说明：简述测评项目背景、被测单位和项目目标等内容。】

1.2 测评依据

【填写说明：分类列出开展测评活动所依据的标准、文件和合同等。下面列出了等级测评过程中主要依据的标准和主要参考的标准，如实际测评中还参考了其他标准，测评机构可根据实际情况在主要参考的标准中进行补充，参考标准不宜过多。如果标准编号的年份发生变化，以最新年份为准。】

测评过程中主要依据的标准：

- (1) GB 17859—1999 《计算机信息系统 安全保护等级划分准则》
- (2) GB/T 22239—2019 《信息安全技术 网络安全等级保护基本要求》
- (3) GB/T 28448—2019 《信息安全技术 网络安全等级保护测评要求》
- (4) GB/T 28449—2018 《信息安全技术 网络安全等级保护测评过程指南》
- (5) GB/T 20984—2022 《信息安全技术 信息安全风险评估方法》

1.3 测评过程

【填写说明：应根据实际测评情况描述等级测评工作流程、各阶段完成的关键任务和工作时间节点等内容。】

1.4 报告分发范围

【填写说明：说明等级测评报告的份数与分发范围。】

2 被测对象描述

2.1 被测对象概述

2.1.1 定级结果

【填写说明：被测对象应为已定级备案的对象，并将被测对象的定级结果填入下表。】

表 2-1 定级结果

被测对象名称	安全保护等级	业务信息安全保护等级	系统服务安全保护等级

2.1.2 业务和采用的技术

【填写说明：描述被测对象及被测对象子系统承载的业务和主要功能，以及采用云计算/移动互联/物联网/工业控制/大数据等技术情况。如果被测对象采用了多种新技术，则不同新技术应单独成段描述。】

2.1.3 网络结构

【填写说明：给出被测对象的网络拓扑结构示意图，并基于示意图说明被测对象的网络结构基本情况，包括网络边界情况、安全区域划分情况（被测对象内部的划分和被测对象所处整体网络的区域划分）、隔离与防护情况、关键网络和服务
器设备部署情况、与其他系统互联情况，以及网络管理方式和管理工具、本地备
份和灾备中心情况等。】

2.2 测评指标

2.2.1 安全通用要求指标

【填写说明：根据被测对象的安全保护等级，选择《基本要求》中对应级别的安全通用要求作为等级测评的指标，以表格形式在下表中列出。】

表 2-2 安全通用要求指标		
安全类	控制点	测评项数

2.2.2 安全扩展要求指标

【填写说明：描述采用移动互联技术、云计算技术的被测对象，以及物联网、工业控制系统、大数据等特殊类型的被测对象，选择《基本要求》中对应级别的安全扩展要求作为等级测评的指标，以表格形式在下表中列出。】

表 2-3 安全扩展要求指标			
扩展类型	安全类	控制点	测评项数
云计算安全扩展要求			
.....			

2.2.3 其他安全要求指标

【填写说明：结合被测评单位要求、被测对象的实际安全需求，以及安全最佳实践经验，以列表形式给出《基本要求》未覆盖或者高于被测对象安全保护等级的安全要求，如行业标准等。】

表 2-4 其他安全要求指标

安全类	控制点	测评项数

2.2.4 不适用安全要求指标

【填写说明：鉴于被测对象的复杂性和特殊性，《基本要求》中的某些要求项可能不适用于所有测评对象，对于这些不适用项应在下表中给出不适用原因。如果单个要求项不适用某个测评对象，应在该测评对象的测评结果记录中说明不适用原因，不用在下表中列出。】

表 2-5 不适用安全要求指标

安全类	控制点	不适用项	不适用原因

2.3 测评对象

2.3.1 测评对象选择方法

【填写说明：依据 GB/T 28449—2018 中测评对象确定原则和方法，结合资产重要程度赋值结果（重要程度赋值为关键、重要和一般），描述本报告中测评对象的选择方法和结果。】

2.3.2 测评对象选择结果

2.3.2.1 物理机房

表 2-6 物理机房

序号	机房名称	物理位置	重要程度

2.3.2.2 网络设备

表 2-7 网络设备

序号	设备名称	是否虚拟设备	系统及版本	品牌及型号	用途	重要程度

2.3.2.3 安全设备

表 2-8 安全设备

序号	设备名称	是否虚拟设备	系统及版本	品牌及型号	用途	重要程度

2.3.2.4 服务器

表 2-9 服务器

序号	设备名称	所属业务应用系统/平台	是否虚拟设备	操作系统及版本	数据库管理系统及版本	中间件及版本	重要程度

2.3.2.5 终端设备

表 2-10 终端设备

序号	设备名称	是否虚拟设备	操作系统及版本	用途	重要程度

2.3.2.6 其他系统或设备

表 2-11 其他系统或设备

序号	设备名称	是否虚拟设备	系统及版本	设备类别/用途	重要程度

序号	设备名称	是否虚拟设备	系统及版本	设备类别/用途	重要程度

2.3.2.7 系统管理软件/平台

表 2-12 系统管理软件/平台

序号	系统管理软件/平台名称	主要功能	版本	所在设备名称	重要程度

2.3.2.8 业务应用系统/平台

表 2-13 业务应用系统/平台

序号	业务应用系统/平台名称	主要功能	业务应用软件及版本	开发厂商	重要程度

2.3.2.9 数据资源

【填写说明：测评对象选择需要覆盖各级各类的数据，并重点关注重要业务数据、个人敏感信息和鉴别数据等。】

表 2-14-a 数据资源

序号	数据类别	所属业务应用	安全防护需求	重要程度

【填写说明：当被测对象为大数据平台/应用/资源时，测评对象选择需要覆盖各级各类的数据，并重点关注重要业务数据、个人敏感信息、鉴别数据、溯源数据等，因此大数据安全测评时还需要填写下表，否则删除。】

表 2-14-b 数据资源

序号	数据类别	数据级别	安全防护需求	所属业务应用					
				数据采集	数据存储	数据处理	数据应用	数据流动	数据销毁

2.3.2.10 安全相关人员

表 2-15 安全相关人员

序号	姓名	岗位/角色	联系方式	所属单位

2.3.2.11 安全管理文档

表 2-16 安全管理文档

序号	文档名称	主要内容

3 单项测评结果分析

【填写说明：以下段落为建议书内容，测评机构可根据情况进行调整。】

单项测评内容包括“2.2.1 安全通用要求指标”、“2.2.2 安全扩展要求指标”和“2.2.3 其他安全要求指标”中涉及的安全类，由已有安全控制措施汇总分析和主要安全问题汇总分析两部分构成，单项测评结果汇总、单项测评结果记录参见报告附录。

3.1 安全物理环境

3.1.1 已有安全控制措施汇总分析

【填写说明：针对测评结果中存在的符合项进行汇总和分析，建议按照控制点对被测对象采用的安全保护措施及其达到的效果等进行详细描述。】

【参考示例】

在安全物理环境方面采取了以下安全措施：

【需要描述物理位置的选择、物理访问控制、防盗窃和防破坏、防雷击、防火、防水和防潮、防静电、温湿度控制、电力供应和电磁防护的主要实现情况】

此外在【XX 安全扩展要求】方面还采取了以下安全措施：

【需要描述扩展要求的主要实现情况】

3.1.2 主要安全问题汇总分析

【填写说明：针对测评结果中存在的部分符合项和不符合项进行汇总和分析，描述主要安全问题及其关联对象，形成被测对象的主要安全问题描述。全部安全问题描述参见 3.13。】

【参考示例】

在安全物理环境方面，未发现明显的安全问题。

在安全物理环境方面存在如下的安全问题：

(1) 【需要问题描述及危害分析】

(2) 【需要问题描述及危害分析】

此外在【XX 安全扩展要求】方面的还存在以下安全问题：

【需要描述扩展要求的主要安全问题】

3.2 安全通信网络

3.2.1 已有安全控制措施汇总分析

3.2.2 主要安全问题汇总分析

3.3 安全区域边界

3.3.1 已有安全控制措施汇总分析

3.3.2 主要安全问题汇总分析

3.4 安全计算环境

【填写说明：网络设备、安全设备、服务器、终端、系统管理软件/平台和业务

应用系统等所涉及的鉴别数据和重要配置数据分别在对应测评对象中汇总测评证据，包括数据完整性、数据保密性和数据备份恢复。】

3.4.1 网络设备

3.4.1.1 已有安全措施汇总分析

3.4.1.2 主要安全问题汇总分析

3.4.2 安全设备

3.4.2.1 已有安全措施汇总分析

3.4.2.2 主要安全问题汇总分析

3.4.3 服务器和终端

3.4.3.1 已有安全措施汇总分析

【参考示例】

在服务器和终端方面采取了以下安全措施：

在身份鉴别方面，采用用户名和口令的方式登录操作系统，对登录的用户进行身份标识和鉴别，身份标识为用户名，具有唯一性。口令信息每 90 天更换一次，由大小写字母、数字和特殊符号组成。启用登录失败处理功能，采用加密通信技术。

在访问控制方面，对登录的用户分配账户以及配置相应的权限，系统中未发现多余、过期的账户，不存在共享账户的情况。

在安全审计方面，启用安全审计功能，审计覆盖每个用户。审计记录包括日

期、时间、用户、事件类型等。对审计记录有定期的备份，且存储期限为 6 个月以上。非超级管理员账户对审计进程无操作权限。

在入侵防范方面，遵循最小安装原则，仅安装需要的组件。不存在多余服务器以及高危端口。通过堡垒机/服务器配置的访问控制策略，对终端接入方式以及地址范围进行限制。

在数据备份恢复方面，采用集群方式保证系统高可用性。

此外在【XX 安全扩展要求】方面还采取了以下安全措施：

【需要描述扩展要求的主要实现情况】

3.4.3.2 主要安全问题汇总分析

【参考示例】

在服务器和终端方面，未发现明显的安全问题。

在服务器和终端方面存在如下安全问题：

(1) 【需要问题描述及危害分析】

(2) 【需要问题描述及危害分析】

此外在【XX 安全扩展要求】方面还存在以下安全问题：

【需要描述扩展要求的主要安全问题】

3.4.4 系统管理软件/平台

3.4.4.1 已有安全控制措施汇总分析

3.4.4.2 主要安全问题汇总分析

3.4.5 业务应用系统/平台

3.4.5.1 已有安全控制措施汇总分析

3.4.5.2 主要安全问题汇总分析

3.4.6 数据资源

【填写说明：数据一般包括鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要个人信息和大数据资源等，这些数据分布在不同的测评对象上，应针对不同类型数据分别从不同测评对象上汇总测评证据。本节只汇总应用系统涉及的重要业务数据、重要个人信息和大数据资源的测评证据，包括数据完整性、数据保密性、剩余信息保护、数据备份恢复和个人信息保护等。网络设备、安全设备、服务器、终端、系统管理软件/平台和业务应用系统等所涉及的鉴别数据和重要配置数据分别在对应测评对象中汇总测评证据，包括数据完整性、数据保密性和数据备份恢复。重要审计数据在安全管理中心-集中管控进行汇总测评证据，包括数据完整性。】

3.4.6.1 已有安全控制措施汇总分析

3.4.6.2 主要安全问题汇总分析

3.4.7 其他系统或设备

【填写说明：其他系统或设备主要包括：移动互联的移动终端、物联网的感知终端、工业控制系统的控制设备等。】

3.4.7.1 已有安全控制措施汇总分析

3.4.7.2 主要安全问题汇总分析

3.5 安全管理中心

【填写说明：集中汇总各被测对象在系统管理、审计管理、安全管理方面的实现情况，以及各类安全措施的集中管控情况。重要审计数据在安全管理中心-集中管控汇总测评证据，包括数据完整性。】

3.5.1 已有安全控制措施汇总分析

3.5.2 主要安全问题汇总分析

3.6 安全管理制度

3.6.1 已有安全控制措施汇总分析

3.6.2 主要安全问题汇总分析

3.7 安全管理机构

3.7.1 已有安全控制措施汇总分析

3.7.2 主要安全问题汇总分析

3.8 安全管理人员

3.8.1 已有安全控制措施汇总分析

3.8.2 主要安全问题汇总分析

3.9 安全建设管理

3.9.1 已有安全措施汇总分析

3.9.2 主要安全问题汇总分析

3.10 安全运维管理

3.10.1 已有安全措施汇总分析

3.10.2 主要安全问题汇总分析

3.11 其他安全要求指标

3.11.1 已有安全措施汇总分析

3.11.2 主要安全问题汇总分析

3.12 验证测试

【填写说明：验证测试包括漏洞扫描、渗透测试等。本章节仅列出验证测试的汇总类结果，详细验证测试结果参见报告附录。如若放弃漏洞扫描或渗透测试，需提供说明材料。】

3.12.1 漏洞扫描

3.12.1.1 漏洞扫描结果统计

【填写说明：描述漏洞扫描工具的名称及其系统版本和规则库版本，给出漏洞扫描工具接入示意图和相关接入点说明。】

(1) 接入点 X 漏洞扫描结果统计

【填写说明：按照下表对漏洞扫描结果进行汇总，详细漏洞扫描结果记录描述参见报告附录。】

接入点 X 的漏洞扫描结果汇总如下表所示。

表 3-1 接入点 X 漏洞扫描结果汇总表

序号	设备名称	系统及版本	安全漏洞数量			
			高	中	低	小计

3.12.1.2 漏洞扫描问题描述

【填写说明：针对系统漏洞扫描或 Web 漏洞扫描结果进行分析，汇总被测对象存在的安全漏洞。严重程度结果为“高”、“中”或“低”。如果被测对象存在的安全漏洞较多，可只描述主要的安全漏洞（如高危安全漏洞）。全部安全漏洞描述参见报告附录。本次测评如果未对被测对象开展漏洞扫描，需提供特殊说明材料，以图片方式提供，说明文件需要有签字、盖章和日期。】

通过对漏洞扫描结果进行分析，[被测对象名称]存在的主要安全漏洞汇总如下表所示。

表 3-2 主要安全漏洞汇总表

序号	安全漏洞名称	关联资产/域名	严重程度

3.12.2 渗透测试

【本次测评如果未对被测系统开展渗透测试，请提供特殊说明材料，以图片方式提供，说明文件需要有签字、盖章和日期。】

3.12.2.1 渗透测试过程说明

【填写说明：简要描述渗透测试的工具、方法和过程等。】

3.12.2.2 渗透测试问题描述

【填写说明：针对渗透测试发现的安全问题进行汇总描述，详细渗透测试过程记录描述参见报告附录。严重程度结果为“高”、“中”或“低”。主要针对身份鉴别、访问控制、入侵防范、数据保密性、剩余信息保护等方面开展弱口令探测、跨站脚本等常见安全漏洞验证测试。对于其他渗透测试中发现但无法归到测评项中的问题也应单独列出，测评项标记为“其他”。】

通过渗透测试发现，[被测对象名称]存在的安全问题汇总如下表所示。

表 3-3 渗透测试结果汇总表

序号	安全问题	关联资产/域名	严重程度	通用/扩展	安全类	控制点	测评项
1	SQL 注入漏洞	OA 应用系统/oa.test.com	高	通用	安全计算环境	入侵防范	d) 应提供数据有效性校验功能，保证通过人际接口输入或者通过通信接口输入的内容符合系统设定要求；
2							
				—	—	—	其他

3.13 安全问题汇总

【填写说明：根据单项测评结果汇总安全问题，各安全类中同一安全问题所关联的测评对象应进行合并。下表可根据实际情况设置为纵向或横向。】

针对单项测评结果中存在的部分符合项和不符合项进行汇总，形成安全问题如下表所示。

表 3-4 安全问题汇总表

问题编号	安全问题	测评对象	通用/扩展	安全类	控制点	测评项
T1	中心机房未部署防盗报警系统且未设置有专人值守的视频监控系统。	中心机房	安全通用要求	安全物理环境	防盗窃和防破坏	c)应设置机房防盗报警系统或设置有专人值守的视频监控系统
T2	安全问题 2					
T3	安全问题 3					
T4	安全问题 4					

4 整体测评

【填写说明：从安全控制点间、区域间对单项测评结果进行分析和整体评价。整体测评分析应从“弥补”和“削弱”两个方向开展分析。】

4.1 安全控制点间安全测评

【参考示例】

用户在登录应用系统时，鉴别信息以明文方式在网络中传输，可能导致鉴别信息被窃取或泄露，进而引发身份冒用、非授权访问等多种安全风险。但实际测评中发现被测应用系统在进行身份鉴别时，采用了不可绕过的两种身份鉴别措施，导致恶意人员获得口令无法轻易登录系统，能够在一定程度上缓解鉴别信息明文传输带来的风险，因此可降低该项问题的安全风险。

4.2 区域间安全测评

【参考示例】

被测对象服务器、数据库单机部署无冗余措施，一旦设备出现故障，可能造成业务中断。但实际测评中发现系统采用多数据中心部署且通过技术手段实现应用级灾备，能够在一定程度上缓解设备故障带来的业务中断风险，因此可降低该项问题的安全风险。

4.3 整体测评结果汇总

【填写说明：根据整体测评结果填写下表，表中问题编号与 3.13 安全问题汇总表中的问题编号一一对应。】

经整体测评后安全问题严重程度变化情况如下表所示。

表 4-1 整体测评结果汇总表

问题编号	安全问题	测评对象	整体测评描述	严重程度变化
T1	鉴别信息以明文方式在网络中传输。	应用系统	被测应用系统在进行身份鉴别时，采用了不可绕过的两种身份鉴别措施，导致恶意人员获得口令无法轻易登录系统，能够在一定程度上缓解鉴别信息明文传输带来的风险。	☐ 升高 ☒ 降低
T2				☐ 升高 ☐ 降低
T3				☐ 升高 ☐ 降低

5 安全问题风险分析

【填写说明：采用风险分析方法分析安全问题可能带来的影响和风险等级，验证测试发现的相关安全问题如不能对应到具体测评项上，应在表中单独列出。下表可根据实际情况设置为纵向或横向。】

5.1 低中高风险安全问题分析

针对等级测评结果中存在的所有安全问题，结合关联资产和威胁分别分析安全问题可能产生的危害结果，找出可能对系统、单位、社会及国家造成的最大安全危害（损失），并根据最大安全危害（损失）的严重程度进一步确定安全问题的风险等级，最大安全危害（损失）结果应结合安全问题所影响业务的重要程度、相关系统组件的重要程度、安全问题严重程度以及安全事件影响范围等进行综合分析。

风险分析结果为“高”、“中”或“低”风险等级的问题如表 5-1 所示。

表 5-1 安全问题风险分析

序号	安全类	安全问题	关联资产	关联威胁	危害分析结果	风险等级

5.2 重大风险隐患分析

【填写说明：将等级测评中发现的高风险问题进行更进一步的风险分析，其中符合重大风险隐患判定原则的问题应当单独列出，并在后果分析中详细说明理由。已整改的风险隐患仍需在此列出，并注明（已整改）。如果没有重大风险隐患，请注明未发现重大风险隐患，例如“经过单项测评结果判定和整体测评，未发现[被测对象名称]存在重大风险隐患。”。测评机构可参考以下示例编制。】

针对等级测评结果中存在的所有高风险安全问题，从安全问题导致的影响程度、安全问题被利用的可能性等方面进一步确认重大风险隐患。其中高风险安全问题导致的安全事件发生概率较大，且一旦发生后将造成业务中断、敏感数据泄露或被篡改、获得系统管理权限或业务权限等严重后果的应当确定为重大风险隐患。[被测对象名称]存在的重大风险隐患具体见下表：

表 5-2 重大风险隐患列表

序号	安全类	安全子类	测评项	重大风险隐患触发项	后果分析	安全问题	关联资产
1	安全计算环境	身份鉴别	a) 应对登录的用户进行身份标识和鉴别，身份标识具有唯一性，身份鉴别信息具有复杂度要求并定期更换；	存在空口令、弱口令、通用口令或无身份鉴别措施。	导致非授权人员可直接访问系统，造成身份冒用、恶意篡改或窃取重要数据等严重后果。	存在可登录的弱口令账户，如长度在 6 位以下，或存在单个、相同、连续数字/字母/字符及常见字典等易猜测的口令。	数据库
2				重大风险隐患 2（已整改）			

序号	安全类	安全子类	测评项	重大风险 隐患触发 项	后果分析	安全问题	关联资产
3				重大风险 隐患 3			
4							

6 总体评价

【填写说明：1、以文字的形式描述被测对象在各安全类中的测评项的符合情况，如果涉及扩展要求的也需统计。2、安全计算环境层面，包括网络设备、安全设备、服务器、系统管理软件、业务应用系统等所有对象的综合判断。对于同一测评项，当所有测评对象均为符合或存在个别不适用时，该测评项为符合；当所有测评对象均为不符合或存在个别不适用时，该测评项为不符合；当所有测评对象均为不适用时，该测评项为不适用，其余情况为部分符合。3、以文字的形式描述被测对象在整个测评过程中所有测评项的统计情况。4、根据单项测评结果汇总要求项符合情况，填写统计汇总数量。】

在安全物理环境通用[和云计算安全扩展要求]方面，本次共测评 XX 项，其中符合项 XX 项，部分符合项 XX 项，不符合项 XX 项，不适用项 XX 项。

.....

依据 GB/T 22239—2019 《信息安全技术 网络安全等级保护基本要求》和 GB/T 28448—2019 《信息安全技术 网络安全等级保护测评要求》的第[一/二/三/四]级要求，[被测对象名称]在本次测评中共测评 XX 项，其中符合项 XX 项，部分符合项 XX 项，不符合项 XX 项，不适用项 XX 项。

根据单项测评结果汇总要求项符合情况如下表所示。

表 6-1 要求项符合情况汇总表

序号	安全类	要求项总数	要求项符合情况			
			符合	部分符合	不符合	不适用
要求项符合情况数量统						

序号	安全类	要求项总数	要求项符合情况			
			符合	部分符合	不符合	不适用
计						
要求项符合率统计						

注：符合率=单项符合总项数/（该级别要求总项数-不适用项数）*100%

7 等级测评结论

【填写说明：说明等级测评结论确定的方法，并最终给出被测对象的等级测评结论。】

等级测评结论主要由被测系统单项符合性进行判定，符合性判定根据被测系统各层面安全保护情况与相应等级安全保护要求的符合程度进行确定。具体判定依据如下表所示。

表 7-1 等级测评结论判定依据

等级测评结论	判定依据
符合	被测系统符合率高于 90%，且无重大风险隐患。
基本符合	被测系统符合率高于 60%，低于 90%；或者符合率为[90%, 100%]且存在重大风险隐患。
不符合	被测系统符合率低于 60%。

依据 GB/T 22239—2019《信息安全技术 网络安全等级保护基本要求》和 GB/T 28448—2019《信息安全技术 网络安全等级保护测评要求》的第[一/二/三/四]级要求，经对[被测对象名称]的安全保护状况进行综合分析评价后，等级测评结论如下：

【填写说明：下面分别给出等级测评结论为符合、基本符合、不符合的参考示例，供测评机构参考。】

1、符合：

[被测对象名称]本次等级测评的符合率为[90%, 100%]，且不存在重大风险隐患，等级测评结论判定为符合。

2、基本符合：

[被测对象名称]本次等级测评的符合率为[60%, 90%)，或者符合率为[90%, 100%]且存在重大风险隐患，等级测评结论判定为基本符合。

3、不符合：

[被测对象名称]本次等级测评的符合率为[0，60%)，等级测评结论判定为不符合。

8 安全问题整改建议

8.1 低中高风险安全问题整改建议

【填写说明：经第五章 5.1 节低中高风险安全问题分析之后，确认为低、中、高风险安全问题的，在本节提出整改建议。】

表 8-1 安全问题整改建议

序号	安全类	安全问题	关联资产	整改建议

8.2 重大风险隐患整改建议

【填写说明：经第五章 5.2 节重大风险隐患分析之后，确认为重大风险隐患的，应当在本节提出整改建议。整改建议应具有针对性、全面性、整体性。既要保证相关整改建议能够落地实施，又要能够全面的、系统性解决系统面临的重大风险隐患。已整改的重大风险隐患，也需在此说明具体的整改措施。】

表 8-2 重大风险隐患列表

序号	安全类	安全子类	重大风险隐患触发项	安全问题	整改建议	关联资产
1	安全计算环境	身份鉴别	存在空口令、弱口令、通用口令或无身份鉴别措施。	存在可登录的弱口令账户，如长度在 6 位以下，或存在单个、相同、连续数字/字母/字符及常见字典等易猜测的口令。	为每个可登录的账户设置符合要求的口令，禁用或删除弱口令账户；设置的口令长度应不低于 8 位，并由大小写字母、特殊字符和数字无规律排列而成；同时应定期排查空口令、弱口令、通用口令的使用情况，及时发现并阻止账户口令违规行为，确保账户安	数据库

序号	安全类	安全子类	重大风险隐患触发项	安全问题	整改建议	关联资产
					全。	
2			重大风险隐患 2 (已整改)			
3			重大风险隐患 3			
4						

【正文结束】

附录 A 被测对象资产

A.1 物理机房

【填写说明：以列表形式给出被测对象的部署机房，包括云服务客户业务系统所涉及多个物理机房。】

附录 A 表-1 物理机房

序号	机房名称	物理位置	重要程度	备注

A.2 网络设备

【填写说明：以列表形式给出被测对象中的网络设备（包括虚拟网络设备），其中 IP 地址第三段使用 “*” 代替，例如 10.1.*.10。】

附录 A 表-2 网络设备

序号	设备名称	是否虚拟设备	系统及版本	品牌及型号	用途	重要程度	IP 地址	备注

注：同类型设备在备注中填写设备数量，但确定为测评对象的设备必须单独列出，且设备名称应唯一。

A.3 安全设备

【填写说明：以列表形式给出被测对象中的安全设备（包括虚拟安全设备），其中 IP 地址第三段使用 “*” 代替，例如 10.1.*.10。】

附录 A 表-3 安全设备

序号	设备名称	是否虚拟设备	系统及版本	品牌及型号	用途	重要程度	IP 地址	备注

注：同类型设备在备注中填写设备数量，但确定为测评对象的设备必须单独列出，且设备名称应唯一。

A.4 服务器

【填写说明：以列表形式给出被测对象中的服务器（包括虚拟设备），其中 IP 地

址第三段使用 “*” 代替，例如 10.1.*.10。】

附录 A 表-4 服务器

序号	设备名称	所属业务应用系统/平台名称	是否虚拟设备	操作系统及版本	数据库管理系统及版本	中间件及版本	重要程度	IP 地址	备注

注：同类型设备在备注中填写设备数量，但确定为测评对象的设备必须单独列出，且设备名称应唯一。

A.5 终端设备

【填写说明：以列表形式给出被测对象中的终端设备，包括业务终端、运维终端、管理终端等，其中 IP 地址第三段使用 “*” 代替，例如 10.1.*.10。】

附录 A 表-5 终端设备

序号	设备名称	是否虚拟设备	操作系统及版本	用途	重要程度	IP 地址	备注

注：同类型设备在备注中填写设备数量，但确定为测评对象的设备必须单独列出，且设备名称应唯一。

A.6 其他系统或设备

【填写说明：以列表形式给出被测对象中的其他系统或设备，包括移动互联的移动终端、物联网的感知终端、工业控制系统的控制设备等，其中 IP 地址第三段使用 “*” 代替，例如 10.1.*.10。】

附录 A 表-6 其他系统或设备

序号	设备名称	是否虚拟设备	系统及版本	设备类别/用途	重要程度	IP 地址	备注

注：同类型设备在备注中填写设备数量，但确定为测评对象的设备必须单独列出，且设备名称应唯一。

A.7 系统管理软件/平台

【填写说明：以列表的形式给出被测对象中的系统管理类软件或平台，包括数据库、中间件、网管软件/平台、安管软件/平台、云计算管理软件/平台等，其中 IP 地址第三段使用 “*” 代替，例如 10.1.*.10。】

附录 A 表-7 系统管理软件/平台

序号	系统管理软件/平台名称	所在设备名称	版本	主要功能	重要程度	IP 地址	备注

注：同类型软件/平台在备注中填写设备数量，但确定为测评对象的设备必须单独列出。

A.8 业务应用系统/平台

【填写说明：以列表的形式给出被测对象中的业务应用系统/平台。主要功能中应描述其访问途径如通过浏览器、客户端或 API 接口等，其中 IP 地址第三段使用 “*” 代替，例如 10.1.*.10。】

附录 A 表-8 业务应用系统/平台

序号	业务应用系统/平台名称	主要功能	业务应用软件及版本	开发厂商	重要程度	IP 地址	备注

A.9 数据资源

【填写说明：以列表形式描述具有相近业务属性和安全需求的数据集合。数据资源一般包括鉴别数据、重要业务数据、重要审计数据、重要配置数据和重要个人信息等。安全防护需求一般从保密性、完整性等方面进行分析。】

附录 A 表-9-a 数据资源

序号	数据类别	所属业务应用	安全防护需求	重要程度

【填写说明：大数据测评对象采用表-9-b 数据资源，否则不用保留下表。】

附录 A 表-9-b 数据资源

序号	数据类别	数据级别	安全防护需求	所属业务应用					
				数据采集	数据存储	数据处理	数据应用	数据流动	数据销毁

A.10 密码产品

【填写说明：密码产品仅作为资产列出，不作为测评对象。】

附录 A 表- 10 密码产品

序号	产品/模块名称	生产厂商	证书编号	密码算法	用途	重要程度

A.11 安全相关人员

【填写说明：以列表形式给出与被测对象安全相关的人员及所属单位，包括安全主管、网络管理员、系统管理员、应用管理员、数据管理员、审计管理员、机房管理员、资产管理员等。】

附录 A 表-11 安全相关人员

序号	姓名	岗位/角色	联系方式	所属单位

A.12 安全管理文档

【填写说明：以列表形式给出与被测对象安全相关的文档，主要包括安全管理制度类文档、记录类文档和其他文档。】

附录 A 表-12 安全管理文档

序号	文档名称	主要内容

附录 B 上次测评问题整改情况说明

【填写说明：描述被测对象上次等级测评结论和综合得分，以及存在的所有安全

问题。针对这些安全问题，核查被测单位安全整改情况，并进行整改情况说明。如果因为标准变动、部署环境变化等原因导致无法核查被测单位安全整改情况，则应在情况说明中阐述原因。如本次测评为被测对象的首次测评，则删除下表并进行文字说明。】

附录 B 表-1 上次测评问题整改情况

序号	安全问题	整改结果	情况说明
		☐ 已整改 ☐ 未整改	
		☐ 已整改 ☐ 未整改	

附录 C 单项测评结果汇总

C.1 安全物理环境

【填写说明: 针对安全通用要求和安全扩展要求的不同控制点对单个测评对象在安全物理环境方面的单项测评结果进行汇总，测评机构应按照以下表格编制。安全扩展要求部分表格中只需列出被测对象所涉及的安全扩展要求。如果被测对象不涉及所有安全扩展要求，则可删除安全扩展要求表格，以下各节要求类同。表格可根据实际情况设置为纵向或横向。】

附录 C 表-1 安全物理环境单项测评结果汇总表（安全通用要求部分）

序号	测评对象	符合情况	安全通用要求									
			物理位置选择	物理访问控制	防盗窃和防破坏	防雷击	防火	防水和防潮	防静电	温湿度控制	电力供应	电磁防护
		符合										
		部分符合										
		不符合										
		不适用										

附录 C 表-2 安全物理环境单项测评结果汇总表（安全扩展要求部分）

序号	测评对象	符合情况	安全扩展要求				
			基础设施位置(云计算)	无线接入点的物理位置(移动互联)	感知节点设备物理防护(物联网)	室外控制设备物理防护(工业控制)	安全物理环境(大数据)
		符合					
		部分符合					
		不符合					
		不适用					

C.2 安全通信网络

C.3 安全区域边界

C.4 安全计算环境

【填写说明：网络设备、安全设备、服务器、终端、系统管理软件/平台和业务应用系统等所涉及的鉴别数据和重要配置数据分别在对应测评对象中汇总测评证据，包括数据完整性、数据保密性和数据备份恢复。】

C.4.1 网络设备

C.4.2 安全设备

C.4.3 服务器和终端

C.4.4 系统管理软件/平台

C.4.5 业务应用系统/平台

C.4.6 数据资源

【填写说明：数据一般包括鉴别数据、重要业务数据、重要审计数据、重要配置数据、重要个人信息和大数据资源等，这些数据分布在不同的测评对象上，应针对不同类型数据分别从不同测评对象上汇总测评证据。本节只汇总应用系统涉及的重要业务数据、重要个人信息和大数据资源的测评证据，包括数据完整性、数据保密性、剩余信息保护、数据备份恢复和个人信息保护等。】

C.4.7 其他系统或设备

C.5 安全管理中心

C.6 安全管理制度

C.7 安全管理机构

C.8 安全管理人员

C.9 安全建设管理

C.10 安全运维管理

C.11 其他安全要求指标

附录 D 单项测评结果记录

D.1 安全物理环境

D.1.1 安全通用要求部分

D.1.1.1 测评对象 1

【填写说明：以下为单项测评结果记录表参考示例，测评机构可根据实际情况调整，但至少应包含下表中内容，以下各节要求类同。】

控制点	测评项	结果记录	符合情况
物理位置的选 择	a) 机房场地应选择 在具有防震、防风 和防雨等能力的 建筑内。	1) 机房所在建筑物具有建筑物抗震设防审批文档； 2) 机房的设计/验收文档中包含对机房具有防震、防风和防雨等能力的设计要求或验收结论； 3) 机房没有窗户，机房的屋顶、墙壁等不存在雨水渗漏的情况； 4) 机房的屋顶、墙体和地面等不存在破损开裂的情况。	符合

D.1.1.2 测评对象 2

D.1.2 安全扩展要求部分

D.1.2.1 测评对象 1

D.1.2.2 测评对象 2

D.2 安全通信网络

D.2.1 安全通用要求部分

D.2.2 安全扩展要求部分

D.2.2.1 XXX 安全扩展要求

D.3 安全区域边界

D.3.1 安全通用要求部分

D.3.2 安全扩展要求部分

D.3.2.1 XXX 安全扩展要求

D.4 安全计算环境

D.4.1 安全通用要求部分

D.4.1.1 网络设备

D.4.1.2 安全设备

D.4.1.3 服务器和终端

D.4.1.4 其他系统或设备

D.4.1.5 系统管理软件/平台

D.4.1.6 业务应用系统/平台

D.4.1.7 数据资源

D.4.2 安全扩展要求部分

D.4.2.1 XXX 安全扩展要求

D.5 安全管理中心

D.5.1 安全通用要求部分

D.5.2 安全扩展要求部分

D.5.2.1 XXX 安全扩展要求

D.6 安全管理制度

D.6.1 安全通用要求部分

D.6.2 安全扩展要求部分

D.6.2.1 XXX 安全扩展要求

D.7 安全管理机构

D.7.1 安全通用要求部分

D.7.2 安全扩展要求部分

D.7.2.1 XXX 安全扩展要求

D.8 安全管理人员

D.8.1 安全通用要求部分

D.8.2 安全扩展要求部分

D.8.2.1 XXX 安全扩展要求

D.9 安全建设管理

D.9.1 安全通用要求部分

D.9.2 安全扩展要求部分

D.9.2.1 XXX 安全扩展要求

D.10 安全运维管理

D.10.1 安全通用要求部分

D.10.2 安全扩展要求部分

D.10.2.1XXX 安全扩展要求

D.11 其他安全要求

附录 E 漏洞扫描结果记录

【填写说明：对网络设备、安全设备、服务器操作系统、数据库管理系统、应用系统和其他系统或设备等的进行洞扫描发现的安全漏洞,主要安全漏洞见下表。】

附录 E 表-1 漏洞扫描主要安全漏洞			
序号	安全漏洞名称	关联资产/域名	严重程度

附录 F 渗透测试结果记录

【填写说明：填写详细的渗透测试过程记录，过程记录中至少包含必要的截图、漏洞名称、漏洞位置、风险等级、漏洞说明及危害等。】

F.1 XX 安全问题 1

F.2 XX 安全漏洞 2

附录 G 重大风险隐患触发项参照表

网络安全等级保护测评过程中，针对等级测评结果中存在的所有安全问题，应采用风险分析的方法进行危害分析和重大风险隐患评估,分析所产生的安全问题被威胁利用的可能性,判断其被威胁利用后对业务信息安全和系统服务安全造成影响的程度，综合评价对定级对象造成的重大风险隐患。

基于以下判定原则，同时符合下列所有条件的安全问题应当判定为重大风险隐患：

——相关性原则：基于网络安全等级保护测评中发现的、可能导致系统面临高风险的安全问题，且针对该问题未采取任一缓解措施；

——严重性原则：安全事件一旦发生后将造成严重后果，包括导致业务中断、重要数据泄露或被篡改，获得系统管理权限或业务权限等；

——高发性原则：在实际运行中由该问题导致的安全事件发生概率较大。

附录 G 表-1 重大风险隐患触发项参照表

序号	安全类	安全子类	测评项	重大风险隐患触发项	安全问题描述
1	安全物理环境	物理访问控制	机房出入口应配置电子门禁系统，控制、鉴别和记录进入的人员。	机房出入口访问控制措施缺失	1) 机房出入口无任何访问控制措施，例如未安装电子或机械门锁（包括机房大门处于未上锁状态），且机房门口无专人值守等； 2) 其他。
2		室外控制设备物理防护	室外控制设备应放置于采用铁板或其他防火材料制作的箱体或装置中并紧固；箱体或装置具有透风、散热、防盗、防雨和防火能力等。	室外控制设备防护缺失	1) 室外控制设备裸露放置、无固定措施，无法做到防水、防盗和防火； 2) 放置控制设备的箱体或装置不具有相关检测验收报告，不具有透风、散热、防盗、防雨和防火能力； 3) 其他。
3	安全通信网络	网络架构	应保证网络设备的业务处理能力满足业务高峰期需要。	网络设备业务处理能力不足	1) 网络设备、安全设备等网络链路上的关键设备性能无法满足高峰期需求； 2) 其他。
4			应实现不同云服务客户虚拟网络之间的隔离。	云计算平台虚拟网络隔离措施缺失	1) 云计算平台未采取网络隔离技术实现不同云服务客户虚拟网络之间的隔离； 2) 其他。
5			应具有根据云服务客户业务需求提供通信传输、边界防护、入侵防范等安全机制的能力。	云计算平台未提供安全防护能力	1) 云计算平台无法提供满足云服务客户业务需要的通信传输、边界防护、入侵防范等安全机制； 2) 其他。
6			工业控制系统与企业其他系统之间应划分为两个区域，区域间应采用单向的技术隔离手段。	工业控制系统网络隔离措施缺失	1) 工业控制系统与企业其他系统之间未划分单独的网络区域； 2) 数据交互未采用单向隔离装置或单向隔离装置未配置有效的访问控制策略； 3) 其他。

序号	安全类	安全子类	测评项	重大风险隐患触发项	安全问题描述
7			工业控制系统内部应根据业务特点划分为不同的安全域，安全域之间应采用技术隔离手段。	工业控制系统所在网络区域划分不当，访问控制措施缺失	1) 工业控制系统所在的生产网络未根据不同工业控制系统业务特点划分不同安全域； 2) 不同安全域之间无任何访问控制措施或访问控制措施无效； 3) 其他。
8		通信传输	在工业控制系统内使用广域网进行控制指令或相关数据交换的应采用加密认证技术手段实现身份认证、访问控制和数据加密传输。	工业控制系统广域网传输控制指令防护措施缺失	1) 未使用基于密码技术的身份鉴别技术； 2) 未使用密码技术保证数据传输过程中的完整性和保密性； 3) 其他。
9	安全区域边界	边界防护	应保证跨越边界的访问和数据流通过边界设备提供的受控接口进行通信。	网络边界接入设备或端口不可控	1) 网络边界链路接入设备未配置明确的上联链路端口； 2) 网络边界链路接入设备端口 IP 及路由策略不明确； 3) 网络边界链路接入设备未关闭不使用的端口； 4) 其他。
10			应限制无线网络的使用，保证无线网络通过受控的边界设备接入内部网络。	无线网络管控措施缺失	1) 内部重要网络与无线网络互联，且不通过任何受控的边界设备或边界设备访问控制策略设置不当； 2) 其他。
11		访问控制	应在网络边界或区域之间根据访问控制策略设置访问控制规则，默认情况下除允许通信外受控接口拒绝所有通信。	重要网络区域边界访问控制措施缺失或配置不当	1) 重要网络区域与其他网络区域之间（包括内部区域边界和外部区域边界）访问控制设备缺失或访问控制措施失效； 2) 其他。

序号	安全类	安全子类	测评项	重大风险隐患触发项	安全问题描述
12			应在工业控制系统与企业其他系统之间部署访问控制设备，配置访问控制策略，禁止任何穿越区域边界的 E-Mail、WEB、Telnet、Rlogin、FTP 等通用网络服务。	工业控制系统与企业其他系统之间未对通用网络服务进行限制	1) 工业控制系统与企业其他系统之间未部署访问控制设备； 2) 工业控制系统与企业其他系统之间未对任何通用的网络服务如 E-Mail、WEB、Telnet、Rlogin、FTP 等进行限制； 3) 其他。
13		入侵防范	应在关键网络节点处检测、防止或限制从外部发起的网络攻击行为。	外部网络攻击防御措施缺失	1) 关键网络节点无任何网络攻击行为检测手段和防护手段； 2) 网络攻击行为检测措施的策略库/规则库半年及以上未更新； 3) 其他。
14			应在关键网络节点处检测、防止或限制从内部发起的网络攻击行为。	内部网络攻击防御措施缺失	1) 关键网络节点无任何网络攻击行为检测手段和防护手段； 2) 网络攻击行为检测措施的策略库/规则库半年及以上未更新； 3) 其他。
15			应采取技术措施对网络行为进行分析，实现对网络攻击特别是新型网络攻击行为的分析。	网络行为分析措施缺失	1) 关键网络节点对新型网络攻击行为网络访问行为无任何分析手段，例如未部署抗 APT 系统、全流量分析系统、沙箱系统、具备行为分析功能的态势感知系统、威胁情报系统等； 2) 基于威胁情报、行为分析模型进行行为分析的安全措施，半年及以上未更新威胁情报库、事件分析模型，无法满足防护需求； 3) 其他。

序号	安全类	安全子类	测评项	重大风险隐患触发项	安全问题描述
16			应能检测到云服务客户发起的网络攻击行为，并能记录攻击类型、攻击时间、攻击流量等。	云计算平台网络攻击防御措施缺失	1) 云计算平台对云服务客户发起的网络攻击行为无任何检测手段； 2) 网络攻击行为检测措施的策略库/规则库半年及以上未更新； 3) 其他。
17		接入控制	应保证只有授权的感知节点可以接入。	非授权感知节点设备能够接入网络中	1) 感知节点设备（例如感知节点接入网关、传感器等设备）未经授权可以接入网络； 2) 其他。
18	安全计算环境	身份鉴别	应对登录的用户进行身份标识和鉴别，身份标识具有唯一性，身份鉴别信息具有复杂度要求并定期更换。	存在空口令、弱口令、通用口令或无身份鉴别措施	1) 存在可登录的空口令账户、无身份鉴别措施或身份鉴别措施可被绕过等； 2) 存在可登录的弱口令账户，如长度在 6 位以下，或存在单个、相同、连续数字/字母/字符及常见字典等易猜测的口令； 3) 多个不同被测对象的管理账户口令相同、或同一被测对象中多个不同管理账户口令相同； 4) 其他。
19			应采用口令、密码技术、生物技术等两种或两种以上组合的鉴别技术对用户进行身份鉴别，且其中一种鉴别技术至少应使用密码技术来实现。	未采用两种或两种以上组合身份鉴别技术	1) 未采用两种或两种以上组合鉴别技术对用户进行身份鉴别； 2) 其他。

序号	安全类	安全子类	测评项	重大风险隐患触发项	安全问题描述
20		访问控制	应由授权主体配置访问控制策略，访问控制策略规定主体对客体的访问规则。	访问控制策略存在缺陷或不完善，存在越权访问可能	1) 业务应用系统/平台访问控制策略存在缺陷或不完善，可非授权访问系统功能模块或查看、操作其他用户的数据； 2) 数据库管理系统访问控制策略存在缺陷或不完善，存在数据库的超级管理员权限被授予非数据库管理员用户、或数据库的默认超级管理员账户被用于非数据库管理用途； 3) 操作系统访问控制策略存在缺陷或不完善。存在以操作系统超级管理员权限运行的数据库、中间件、应用程序等非操作系统级进程或服务； 4) 其他。
21		入侵防范	应关闭不需要的系统服务、默认共享和高危端口。	开启多余的系统服务、默认共享和高危端口	1) 开启多余的系统服务、默认共享和高危端口，且可被远程访问； 2) 其他。
22			应能发现可能存在的已知漏洞，并在经过充分测试评估后，及时修补漏洞。	存在可被利用的高危安全漏洞	1) 通过互联网管理或访问的系统或设备，存在外界披露的可被利用的高危安全漏洞； 2) 通过非互联网等公共通信网络管理或访问的系统或设备，经测试验证确认存在缓冲区溢出、越权访问、远程代码执行等可被利用的高危安全漏洞； 2) 其他。
23		恶意代码防范	应采用免受恶意代码攻击的技术措施或主动免疫可信验证机制及时识别入侵和病毒行为，并将其有效阻断。	恶意代码防范措施缺失	1) 未采取恶意代码检测和清除措施； 2) 恶意代码防范产品授权已过期； 3) 恶意代码特征库、规则库等一个月以上未更新； 4) 其他。

序号	安全类	安全子类	测评项	重大风险隐患触发项	安全问题描述
24		数据保密性	应采用密码技术保证重要数据在传输过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等。	重要数据明文传输	1) 鉴别信息、重要个人信息或重要业务数据等以明文的方式在网络环境中传输； 2) 其他。
25			应采用密码技术保证重要数据在存储过程中的保密性，包括但不限于鉴别数据、重要业务数据和重要个人信息等。	重要数据明文存储	1) 鉴别信息、重要个人信息、具有保密性需求的重要业务数据以明文的方式存储； 2) 其他。
26		数据备份恢复	应提供重要数据的本地数据备份与恢复功能。	重要数据无本地备份措施	1) 重要数据未提供任何数据备份措施； 2) 重要数据备份到互联网网盘或相关存储环境； 3) 其他。
27	综合类	——	——	获取被测系统关联系统权限	1) 获取了最高管理员权限或子管理员权限或普通用户权限； 2) 其他。
28		——	——	获取被测系统权限	1) 获取了被测系统权限； 2) 其他。
29		——	——	互联网暴露面过宽	1) 大型专网未能有效收口； 2) 移动应用后台接口成为新的暴露点； 3) 应用私搭乱建，管理不到位，存在防护盲区； 4) 违规打通内网与互联网连接； 5) 第三方接入缺乏安全管理与整体管控； 6) 其他。

序号	安全类	安全子类	测评项	重大风险隐患触发项	安全问题描述
30		——	——	数据管理不规范	1) 违背最小化原则信息量泄露过多; 2) 数据传输、存储、备份不规范; 3) 其他。
31		——	——	“神经中枢”系统缺乏重点加固	1) 集权系统鉴别机制存在缺陷; 2) 管理后台自身架构存在漏洞; 3) 集权系统支撑环境存在漏洞; 4) 域控系统缺乏重点防护措施; 5) 其他。
32		——	——	安全管理运维水平不足	1) 供应链管控不力,成为迂回攻击跳板; 2) 网络资产底数不清晰,老旧资产、测试系统未下线; 3) 基层单位安全防护能力薄弱,极易成为攻击突破口; 4) 员工安全意识不足,易被社工攻击利用; 5) 公开漏洞未修复; 6) 0Day 漏洞攻击难以监测发现; 7) 网络安全监测存在盲点导致难以及时发现隐蔽入侵行为,缺乏对攻击监测数据的分析; 8) 其他。
33	其他 (可自行补充)			——	——

附录 H 重大风险隐患及整改情况

【填写说明：描述被测对象存在的全部重大风险隐患，并详细说明重大风险隐患发现确认的过程。对于已完成整改的，应当详细说明重大风险隐患整改情况，并提供整改后无法利用的理由或相关证明材料。测评机构可参考如下两个示例进行编写。】

H.1 重大风险隐患 1（已整改）

【参考示例】

【相关性】：在对 XXX 系统进行等级测评的过程中，测评人员通过配置核查发现数据库存在可登录的弱口令账户（用户名“root”，口令“admin”），符合《网络安全等级保护高风险判定实施指引》中的问题描述“存在可登录的弱口令账户，如长度在 6 位以下，或存在单个、相同、连续数字/字母/字符及常见字典等易猜测的口令”。同时数据库允许远程管理，且未采取登录地址限制、登录终端限制、物理位置限制等远程登录管控措施，也不具备不可绕过的两种或两种以上组合的身份鉴别措施，通过整体测评和风险分析后，被认定为高风险安全问题。

【严重性】：该问题一旦被利用，非授权人员可直接访问数据库，读取重要数据或者修改数据库中的内容，造成恶意篡改或窃取重要数据等严重后果。

【高发性】：经测试验证，测评人员可从互联网上传木马脚本控制 Web 服务器，并以此为跳板，使用弱口令登录数据库，从而获得相应权限，造成数据篡改或泄露，利用该问题对系统造成重大危害的可能性极大。

综合以上分析，XXX 系统存在可登录的数据库弱口令账户，利用该问题可访问数据库，进而获取或修改重要数据的重大风险隐患。

已整改情况：已为每个可登录的账户设置符合要求的口令，禁用或删除弱口令账户；设置的口令长度均不低于 8 位，并由大小写字母、特殊字符和数字无规律排列而成；同时定期排查空口令、弱口令、通用口令的使用情况，及时发现并阻止账户口令违规行为，确保账户安全。

H.2 重大风险隐患 2

【参考示例】

【相关性】：在对 XXX 系统进行等级测评的过程中，测评人员通过渗透测试发现 XXXX 系统存在 Shiro 反序列化漏洞，可利用该漏洞注入恶意代码片段，在服务器上运行任意命令，从而控制服务器或应用程序，符合《网络安全等级保护测评高风险判定实施指引》6.4.3.2“存在可被利用的高危安全漏洞”中的问题描述。

【严重性】：该问题一旦被利用，攻击者将会获得管理员权限，可以通过该漏洞执行任意的恶意代码，从而完全控制受害服务器，读取、修改、删除服务器上的任意数据，一方面为下一步内网横向攻击其他系统资源提供基础，以“合规”的身份攻击内网其他系统目标，同时以此为据点监控内部网络行为，获取内部网络数据；另一方面，可以作为跳板，通过种植病毒木马，建立反向外联通道，将内部网络数据实时传输至外部网络，造成内部信息泄露。

【高发性】：在 XXX 系统测试过程中，由于该系统虽然部署主机杀毒软件、反病毒网关等安全设备，但由于病毒库更新不及时，以及相关区域边界策略设置不合理，并未对测试行为进行有效监控和拦截，攻击者进入内网即可访问到受害服务器，利用该漏洞对系统造成重大危害的可能性极大。

综合以上分析，XXX 系统存在 Shiro 反序列化漏洞，且安全措施不完善、边界策略不合理，导致攻击者能够获得管理员权限，进而控制相关服务器的重大风险隐患。

附录 I 威胁列表

【填写说明：建议测评机构依据最新版本 GB/T 20984 制定威胁列表，以下为参考示例。】

附录 G 表-1 威胁列表

序号	威胁分(子)类	威胁描述
1	物理损害	对业务实施或系统运行产生影响的物理损害

序号	威胁分(子)类	威胁描述
2	自然灾害	自然界中所发生的异常现象，且对业务开展或系统运行会造成危害的现象和事件。
3	信息损害	对系统或资产中的信息产生破坏、篡改、丢失、盗取等行为。
4	技术失效	信息系统所依赖的软硬件设备不可用。
5	未授权行为	超出权限设置或授权进行操作或者使用的行为。
6	功能损害	造成业务或系统运行的部分功能不可用或者损害。
7	供应链失效	业务或系统所依赖的供应商、接口等不可用。
8	抵赖	否认所做的操作。

附录 J 云计算平台测评及整改情况

【填写说明：本附录仅适用于被测对象为云服务客户业务应用系统，且由独立定级的云计算平台提供平台支撑的情况，否则删除。如果云租户部署在多个云平台上，提供多个云平台材料。本附录内容由云服务商提供，主要包括两部分：一是云计算平台等级测评报告中的等级测评结论表、等级测评结论扩展表、重大风险隐患及整改建议；二是云计算平台提供方针对这些重大风险隐患的整改情况说明。】

附录 K 大数据平台测评及整改情况

【填写说明：本附录仅适用于被测对象为大数据应用/资源，且由独立定级的大数据平台提供平台支撑的情况，否则删除。本附录内容由大数据平台提供方提供，主要包括两部分：一是大数据平台等级测评报告中的等级测评结论表、等级测评结论扩展表、重大风险隐患及整改建议；二是大数据平台提供方针对这些重大风险隐患的整改情况说明。】

【全文结束】